

Morphic Studio

Document 29 — Security & Privacy Framework (Expanded Specification)

Document ID: MS-029

Version: 2.0

Status: Expanded Specification

Priority: Critical Platform Infrastructure

Purpose

The Security & Privacy Framework establishes the principles, architecture, controls, and operational practices that protect Morphic Studio, its creators, their creative assets, and all platform services.

It defines how security is integrated throughout the platform rather than added as a separate feature.

Vision

Creators should trust that:

- Their stories are protected.
- Their characters remain private.
- Their projects cannot be accidentally lost.
- Their accounts remain secure.
- Their intellectual property belongs to them.

Security should strengthen confidence without reducing usability.

Core Philosophy

Trust is a feature.

Every design decision should consider:

- Confidentiality
 - Integrity
 - Availability
 - Privacy
 - Accountability
-

Security Objectives

The framework shall:

- Protect user identities.
 - Protect creative assets.
 - Protect platform infrastructure.
 - Prevent unauthorized access.
 - Detect suspicious behavior.
 - Preserve audit history.
 - Support future compliance requirements.
-

Security Principles

Every component should follow:

- Least Privilege
 - Defense in Depth
 - Secure by Default
 - Zero Trust Principles (future)
 - Principle of Explicit Authorization
 - Privacy by Design
-

Security Domains

The framework covers:

Identity Security

- Authentication
- Authorization
- Session management
- Credential protection

Data Security

- Encryption
- Storage protection
- Backup security
- File integrity

Application Security

- Input validation
- Output encoding
- Dependency management
- API security

Infrastructure Security

- Server hardening
- Secure deployment
- Environment isolation
- Secrets management

AI Security

- Prompt validation
- Model access control
- API key protection
- AI provider isolation
- Output validation

Operational Security

- Logging
 - Monitoring
 - Incident response
 - Recovery procedures
-

Asset Protection

Creative assets receive additional protection through:

- Ownership tracking
- Version history
- Permission enforcement
- Secure backups
- Integrity verification

Every asset remains attributable to its creator.

Encryption

Sensitive information should be protected:

In Transit

- HTTPS
- TLS

At Rest

- Database encryption where appropriate
- Encrypted secrets
- Secure backup storage

Passwords must always be hashed using modern password hashing algorithms.

Secrets Management

Secrets include:

- API Keys
- Database Credentials
- AI Provider Tokens
- Storage Credentials
- Email Service Keys

Secrets must never be stored directly in application source code.

Access Control

Every request evaluates:

User



Authentication



Workspace



Role



Permissions



Requested Resource



Decision

Access should always be explicit.

Audit Logging

Important events include:

- Login
- Logout
- Permission changes
- Asset deletion
- Workflow approvals
- Project exports
- AI provider changes

- Administrative actions

Audit records should remain tamper-resistant.

Privacy Principles

The platform should:

- Collect only necessary information.
 - Explain why information is collected.
 - Allow users to manage their data.
 - Respect creator ownership.
 - Support future privacy regulations.
-

User Stories

As a creator, I want my unpublished stories to remain private.

As a creator, I want confidence that my assets belong to me.

As an administrator, I want visibility into security events.

As a workspace owner, I want to manage access responsibly.

Functional Requirements

The Security Framework shall provide:

- Authentication enforcement.
 - Authorization enforcement.
 - Secure communications.
 - Audit logging.
 - Backup protection.
 - Session management.
 - API protection.
 - Secure configuration.
 - Activity monitoring.
-

Security Dashboard

Future administrative dashboards may include:

- Security Alerts
 - Failed Login Attempts
 - Active Sessions
 - Permission Changes
 - Audit Timeline
 - API Usage
 - Provider Status
 - Backup Status
-

Database Entities

Core entities include:

- SecurityEvent
 - AuditLog
 - Incident
 - SecretReference
 - PermissionAudit
 - AccessLog
 - SessionHistory
-

API Considerations

Potential endpoints include:

- Retrieve Audit Logs
 - Security Events
 - Session Management
 - Permission Review
 - Incident Reporting
 - API Key Management
-

Non-Functional Requirements

The Security Framework should:

- Scale with platform growth.
 - Remain continuously monitored.
 - Minimize attack surface.
 - Protect confidential information.
 - Recover gracefully after incidents.
-

Error Handling

If unauthorized access is detected:

- Deny access.
- Record the event.
- Notify administrators when appropriate.

If suspicious activity occurs:

- Preserve evidence.
 - Alert relevant users.
 - Support future automated mitigation.
-

Incident Response

Future operational procedures include:

Detection

↓

Classification

↓

Containment

↓

Investigation



Recovery



Review



Improvement

Security incidents should become opportunities to strengthen the platform.

Future Expansion

Future versions may include:

- Multi-factor authentication.
 - Hardware security keys.
 - Security scoring.
 - AI-assisted threat detection.
 - Compliance reporting.
 - Data residency controls.
 - Customer-managed encryption keys.
 - Enterprise governance.
-

Acceptance Criteria

The Security & Privacy Framework succeeds when creators can confidently trust Morphe Studio with their identities, creative work, and intellectual property while administrators maintain visibility and control over platform security.

Key Principle

Security is not an obstacle to creativity—it is the foundation that allows creators to confidently invest their imagination, time, and intellectual property into Morphe Studio.

End of Document 29